Security Scan Summary

Target: **orangehrm/orangehrm** · branch: **main**
Scan run: 20261106 (3)
Status: **PERLU DIPERBAIKI**

5	38	75	180
CRITICAL	HIGH	MEDIUM	LOW

KETERANGAN

JENIS SCAN	SCOPE & REMEDIATION	COMMAND
SCA Snyk Open Source	Software Composition Analysis: the dependency tree from the manifest/lockfile (package.json, pom.xml, etc.) is matched against a vulnerability database (CVE). **Remediation:** upgrade to the version in "Fixed in" after checking the upgrade path on snyk.io. For a **transitive dependency** (see "Introduced through"), upgrade the direct dependency that pulls it in. Pick the nearest safe version, check for breaking changes, then regression test. If there is no fix / it is not exploitable, mitigate or ignore with a documented justification.	`snyk test --all-projects`
SAST Snyk Code	Static Application Security Testing: the source code is analyzed with data-flow / taint analysis for vulnerability patterns (SQL injection, XSS, path traversal, hardcoded secrets). **Remediation:** validate the source → sink data flow at the reported location (it can be a false positive), then fix it, e.g. parameterized queries, input validation, output encoding. If it is a false positive, ignore with a documented justification.	`snyk code test`
GITLEAKS local scan	Secret scanning (regex + entropy) for passwords, tokens, API keys, and private keys across **the entire git history**, including commits that have since been removed from HEAD. Secret values are redacted. **Remediation:** treat as compromised: rotate/revoke first, then move the secret into an environment variable / secret manager.	`gitleaks git --redact`
TRIVY local scan	*Repos with a Dockerfile.* IaC misconfiguration scanning: the Dockerfile is evaluated against security best-practice checks, e.g. container running as root, unpinned base image (:latest), no HEALTHCHECK. **Remediation:** follow the "Resolution" on each finding.	`trivy config .`

SEVERITY	
C	**Critical**
H	**High**
M	**Medium**
L	**Low**

STATUS REPO	
PERLU DIPERBAIKI	There is a Critical/High/Medium finding, or a secret.
AMAN	No Medium+ finding and no secret found.
GAGAL SCAN	A scan could not complete; coverage is incomplete, not proven safe.

ISTILAH PER TOOL

Glossary istilah dan field yang muncul di PDF detail tiap jenis scan.

Jenis scan	Istilah	Arti
SEMUA SCAN	**Severity (C / H / M / L)**	Critical / High / Medium / Low, umumnya diturunkan dari CVSS score atau rule severity. Status repo dan ringkasan .txt memakai threshold **Medium+**; Low tetap tercantum di PDF detail.
	CVE / CWE	**CVE** = identifier publik untuk satu vulnerability spesifik pada versi software tertentu. **CWE** = kategori weakness (mis. CWE-89 SQL Injection, CWE-22 Path Traversal, CWE-798 Hard-coded Credentials).
	False positive	Finding yang tidak benar-benar exploitable di konteks aplikasi. Wajib divalidasi manual sebelum di-ignore, dan ignore harus disertai justifikasi.
SCA Snyk Open Source	**Introduced through**	Dependency path dari project ke vulnerable package. Path lebih dari satu level = **transitive dependency**; remediation dilakukan dengan upgrade **direct dependency** yang membawanya.
	Fixed in	Versi minimum package yang sudah mengandung patch. Kosong = no fix available (mitigasi atau ganti library).
	CVSS score / vector	Base score 0.0–10.0 beserta vector string (AV, AC, PR, UI, S, C/I/A) dari standar CVSS v3.x/v4.
	Exploit maturity	Ketersediaan exploit publik: No Known Exploit, Proof of Concept, Functional, Mature. Makin mature, makin tinggi likelihood exploitation.
SAST Snyk Code	**Location / data flow**	File:line yang rentan dan taint flow **source** → **sink** (input tidak tepercaya mencapai operasi berbahaya tanpa sanitasi).
	Rule	ID rule Snyk Code yang terpicu, mis. javascript/Sqli, go/PT (Path Traversal).
GITLEAKS local scan	**Masih ada di kode**	File berisi secret masih ada di HEAD branch yang di-scan. **Prioritaskan** (rotate + remove).
	Hanya di history	File sudah dihapus dari HEAD, tapi secret masih bisa di-retrieve dari git history. **Tetap harus di-rotate.**
	Rule / Entropy	**Rule** = detector yang cocok (mis. generic-api-key, private-key, jwt). **Entropy** = Shannon entropy nilai yang cocok; makin tinggi, makin mungkin secret asli (bukan placeholder).
	First introducing commit	Commit, author, dan timestamp saat secret pertama kali masuk ke history, untuk investigasi dan menentukan exposure window.
TRIVY local scan	**Pass / Fail**	Jumlah policy check Dockerfile yang terpenuhi (PASS) dan yang dilanggar (FAIL).
	Check ID (DS-xxxx)	ID policy Trivy untuk Dockerfile, mis. DS-0001 unpinned :latest, DS-0002 run as root, DS-0026 tanpa HEALTHCHECK.
	File-level finding	Finding tanpa line number karena yang dilanggar adalah instruksi yang tidak didefinisikan (mis. USER, HEALTHCHECK).

orangehrm/orangehrm branch: main	PERLU DIPERBAIKI	5 C	38 H	75 M	180 L

JENIS SCAN	PROJECT	ISSUES
SCA Snyk Open Source	orangehrm	5 C 36 H 64 M 4 L
SAST Snyk Code	orangehrm	0 C 1 H 11 M 175 L
GITLEAKS local scan	orangehrm	358 Secret
TRIVY local scan	orangehrm	0 C 1 H 0 M 1 L